

UNIVERSIDAD MAYOR DE SAN ANDRES

Carrera de Informática – Seguridad de la Información



Proyecto: Evaluación de seguridad de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – Evaluación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Bautista Apaza Ruben Ignacio

Fecha: 18/05/26

Clasificación del documento: Académico / Confidencial

Análisis hipotético y planificación ofensiva

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis de superficie de ataque, identificación teórica de vulnerabilidades y simulación de vectores de ataque sobre el sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

Debido a limitaciones del entorno, las evaluaciones fueron realizadas mediante análisis audiovisual del sistema y revisión conceptual de seguridad ofensiva.

2. OBJETIVOS

2.1 Objetivo General

Ejemplo:

Evaluar teóricamente la seguridad del sistema Pet Spa mediante técnicas de reconocimiento, análisis de autenticación, revisión de controles RBAC (Control de Acceso Basado en Roles) y simulación de pruebas de intrusión.

2.2 Objetivos Específicos

- Analizar el sistema de autenticación.
- Evaluar posibles debilidades JWT (JSON Web Token).
- Identificar riesgos de escalación de privilegios.
- Evaluar políticas de contraseñas.
- Detectar malas prácticas visibles.
- Proponer medidas de mitigación.

3. ALCANCE

Aquí defines qué módulos se analizaron.

Ejemplo:

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Recepción
- Groomer
- Cliente
- Gestión de usuarios

- Reportes
- Reservas
- Historiales

LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica basada en material audiovisual proporcionado por terceros. No se contó con acceso directo al entorno funcional, servidor, base de datos, APIs ni tráfico real de red, por lo que no fue posible ejecutar explotación activa ni validaciones prácticas de vulnerabilidades.

4. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis visual de autenticación
- Evaluación OWASP Top 10
- Simulación de vectores de ataque
- Evaluación RBAC
- Análisis de malas prácticas

5. RECONOCIMIENTO Y SUPERFICIE DE ATAQUE

Hallazgo	Observación	Superficie de ataque	Vulnerabilidad teórica	Pruebas hipotéticas	Simulación de ataque	Riesgo	Impacto	Severidad	Mitigación	Mejora recomendada
Ausencia total de MFA y CAPTCHA en accesos administrativos	El administrador accede únicamente mediante usuario y contraseña sin CAPTCHA ni autenticación multifactor.	Login administrador, autenticación, sesiones	Alto riesgo de compromiso de cuentas privilegiadas	Fuerza bruta, credential stuffing, phishing	Un atacante podría obtener acceso administrativo utilizando credenciales filtradas o ataques automatizados.	Compromiso total del sistema	Crítico	Crítica	MFA obligatorio, CAPTCHA y monitoreo de accesos	Implementar MFA obligatorio y protección adaptativa de login
Formularios administrativos con validaciones débiles	Los formularios permiten ingresar cualquier tipo de información sin restricciones visibles.	Panel administrativo, formularios internos	Inyección de datos inválidos o maliciosos	Payloads XSS, caracteres especiales, inputs extensos	Un atacante podría ingresar datos corruptos o scripts maliciosos afectando la aplicación y BD.	Corrupción de datos y posibles ataques persistentes	Alto	Alta	Sanitización y validaciones estrictas backend/frontend	Implementar validaciones tipadas y control estricto de entradas
Ausencia de activación segura en cuentas de empleados	Las cuentas de empleados no utilizan tokens de activación ni validación de identidad.	Creación de empleados, gestión de cuentas	Activación inmediata de cuentas potencialmente fraudulentas	Creación masiva de empleados falsos, suplantación	Un atacante con acceso administrativo podría generar cuentas falsas listas para uso inmediato.	Accesos indebidos y abuso interno	Alto	Alta	Tokens de activación y validación por correo	Implementar flujo seguro de activación y verificación de identidad
Ausencia de MFA y CAPTCHA en empleados	Los empleados ingresan únicamente con correo y contraseña sin controles adicionales.	Login empleados, sesiones	Exposición elevada a robo de credenciales	Credential stuffing, phishing, bots	Un atacante podría acceder fácilmente a cuentas comprometidas.	Acceso no autorizado	Alto	Alta	MFA obligatorio y CAPTCHA adaptativo	Aplicar MFA obligatorio para empleados
Registro de clientes vulnerable a automatización	El registro de clientes permite ingresar cualquier información y no posee CAPTCHA ni controles anti-bot.	Registro, formularios públicos, BD	Automatización masiva y generación de cuentas basura	Bots, flood de registros, correos temporales	Un atacante podría llenar la base de datos con cuentas falsas y degradar el sistema.	Saturación de recursos y contaminación de BD	Alto	Alta	CAPTCHA, rate limiting y validación anti-bot	Implementar controles de reputación y límites de registros
Activación de cuenta insuficiente	Aunque existe activación por correo, posteriormente el login continúa sin CAPTCHA ni MFA.	Activación, autenticación	Persistencia de vulnerabilidades en acceso posterior	Fuerza bruta, credential stuffing	Un atacante podría comprometer cuentas activadas sin segunda capa de seguridad.	Robo de cuentas	Alto	Alta	MFA y protección adaptativa de login	Añadir MFA posterior a activación
Sistema de logs limitado y no auditable	Los logs solo son accesibles desde la base de datos y no mediante panel administrativo o SIEM.	Logs, auditoría, BD	Baja capacidad de monitoreo y respuesta ante incidentes	Alteración de logs, eliminación de evidencias	Un atacante con acceso privilegiado podría modificar registros sin trazabilidad adecuada.	Pérdida de auditoría y monitoreo	Alto	Alta	SIEM, logs centralizados e inmutables	Integrar SIEM y monitoreo en tiempo real
Gestión de roles insuficiente	Existen roles de invitados y controles débiles visibles en la administración de accesos.	RBAC, panel administrativo	Posibles fallas de autorización y escalación de privilegios	Manipulación de roles, accesos indebidos	Un atacante podría aprovechar controles débiles para acceder a funcionalidades restringidas.	Escalación de privilegios	Crítico	Crítica	RBAC robusto y validación estricta	Implementar control centralizado de privilegios
Validación débil de correos electrónicos	El sistema acepta cualquier correo Gmail y no diferencia dominios corporativos propios.	Registro y autenticación	Creación de identidades falsas y baja trazabilidad	Uso de correos temporales y desechables	Un atacante podría crear múltiples identidades falsas para ocultar actividad maliciosa.	Suplantación y abuso de cuentas	Medio-Alto	Media-Alta	Restricción de dominios y reputación de correo	Implementar validación avanzada y dominios corporativos
Contraseñas hasheadas correctamente pero con controles insuficientes	Las contraseñas están hasheadas, pero existen debilidades generales en autenticación y validación.	Base de datos y autenticación	Protección parcial frente a ataques offline	Validación de hashes y políticas de contraseña	Aunque los hashes protegen parcialmente las contraseñas, otras debilidades permiten comprometer cuentas.	Compromiso indirecto de autenticación	Medio	Media	Mantener hashing seguro y fortalecer autenticación	Migrar a Argon2id y complementar con MFA

6. RECOMENDACIONES GENERALES Y CONCLUSIONES ESPECIFICADA POR CASOS

Hallazgo 1 — Ausencia total de MFA y CAPTCHA en accesos administrativos

Observación

El administrador accede únicamente mediante usuario y contraseña sin autenticación multifactor ni CAPTCHA visibles.

Superficie de ataque

- Login administrador
- Sistema de autenticación
- Gestión de sesiones

Vulnerabilidad teórica

Alto riesgo de compromiso de cuentas privilegiadas mediante ataques automatizados o reutilización de credenciales filtradas.

Pruebas hipotéticas

- Fuerza bruta
- Credential stuffing
- Phishing
- Ataques automatizados

Simulación de ataque

Un atacante podría utilizar listas filtradas de usuarios y contraseñas para obtener acceso administrativo completo al sistema.

Riesgo

- Compromiso total del panel administrativo
- Robo de información sensible
- Escalación total de privilegios

Impacto: Crítico

Severidad: Crítico

Mitigación

- Implementar MFA obligatorio
- CAPTCHA adaptativo
- Rate limiting

- Alertas de accesos sospechosos

Mejora recomendada

Implementar MFA obligatorio basado en aplicaciones OTP y CAPTCHA dinámico tras intentos fallidos.

Hallazgo 2 — Formularios administrativos con validaciones débiles

Observación

Los formularios de creación de empleados permiten ingresar información arbitraria sin validaciones estrictas visibles.

Superficie de ataque

- Formularios administrativos
- Gestión de empleados
- Base de datos

Vulnerabilidad teórica

Posible ingreso de datos inválidos, payloads maliciosos o corrupción lógica de la información almacenada.

Pruebas hipotéticas

- Inserción de scripts
- Inputs extremadamente largos
- Caracteres especiales
- Payloads XSS

Simulación de ataque

Un atacante podría almacenar datos maliciosos que afecten la integridad del sistema o provoquen ejecución de scripts persistentes.

Riesgo

- Corrupción de datos
- XSS almacenado
- Inestabilidad del sistema

Impacto: Alto

Severidad: Alto

Mitigación

- Sanitización de entradas

- Validación backend
- Restricción de formatos y longitudes

Mejora recomendada

Implementar validaciones tipadas y sanitización centralizada en frontend y backend.

Hallazgo 3 — Ausencia de activación segura para cuentas de empleados

Observación

Las cuentas de empleados son creadas directamente sin tokens de activación ni validación adicional por correo electrónico.

Superficie de ataque

- Gestión de empleados
- Creación de cuentas
- Sistema administrativo

Vulnerabilidad teórica

Creación inmediata de cuentas potencialmente fraudulentas o mal configuradas.

Pruebas hipotéticas

- Creación masiva de empleados falsos
- Suplantación de identidad
- Registro de cuentas maliciosas

Simulación de ataque

Un atacante con acceso administrativo podría generar cuentas activas inmediatamente sin verificación adicional.

Riesgo

- Accesos indebidos
- Abuso interno
- Persistencia de cuentas fraudulentas

Impacto: Alto

Severidad: Alta

Mitigación

- Tokens de activación
- Validación por correo
- Confirmación de identidad

Mejora recomendada

Implementar flujo de activación seguro y aprobación administrativa de nuevas cuentas.

Hallazgo 4 — Ausencia de MFA y CAPTCHA en cuentas de empleados

Observación

Los empleados acceden únicamente mediante correo y contraseña sin autenticación multifactor ni CAPTCHA.

Superficie de ataque

- Login empleados
- Gestión de sesiones

Vulnerabilidad teórica

Exposición elevada a robo de credenciales y accesos automatizados.

Pruebas hipotéticas

- Credential stuffing
- Fuerza bruta
- Phishing
- Automatización de login

Simulación de ataque

Un atacante podría comprometer cuentas de empleados usando credenciales filtradas.

Riesgo

- Acceso no autorizado
- Robo de información
- Escalación lateral

Impacto: Alto

Severidad: Alto

Mitigación

- MFA obligatorio
- CAPTCHA adaptativo
- Rate limiting

Mejora recomendada

Implementar MFA obligatorio para empleados y monitoreo de accesos sospechosos.

Hallazgo 5 — Registro de clientes vulnerable a automatización

Observación

El registro de clientes permite ingresar cualquier información sin controles anti automatización visibles.

Superficie de ataque

- Registro público
- Formularios
- Base de datos

Vulnerabilidad teórica

Posible abuso mediante creación masiva de cuentas falsas y contaminación de la base de datos.

Pruebas hipotéticas

- Bots automatizados
- Flood de registros
- Uso de correos temporales

Simulación de ataque

Un atacante podría automatizar registros masivos para saturar almacenamiento y degradar el sistema.

Riesgo

- Saturación de la BD
- Denegación parcial de servicio
- Contaminación de registros

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA
- Rate limiting
- Validación anti-bot

Mejora recomendada

Implementar controles de reputación de correo y límites por IP/dispositivo.

Hallazgo 6 — Activación de cuenta insuficiente frente a amenazas posteriores

Observación

Aunque existe activación mediante correo electrónico, posteriormente el sistema continúa sin MFA ni CAPTCHA.

Superficie de ataque

- Login
- Gestión de sesiones
- Autenticación

Vulnerabilidad teórica

Persistencia de debilidades críticas posteriores a la activación inicial.

Pruebas hipotéticas

- Fuerza bruta
- Credential stuffing
- Automatización de accesos

Simulación de ataque

Un atacante podría comprometer cuentas válidamente activadas debido a la ausencia de capas adicionales de protección.

Riesgo

- Compromiso de cuentas
- Robo de información

Impacto: Alto

Severidad: Alto

Mitigación

- MFA
- CAPTCHA adaptativo
- Monitoreo de accesos

Mejora recomendada

Agregar autenticación multifactor posterior a la activación de cuenta.

Hallazgo 7 — Sistema de logs limitado y no auditable

Observación

Los logs solo pueden visualizarse desde la base de datos y no desde el panel administrativo. No se observa integración SIEM.

Superficie de ataque

- Logs
- Auditoría
- Base de datos

Vulnerabilidad teórica

Baja capacidad de monitoreo, detección y respuesta ante incidentes.

Pruebas hipotéticas

- Manipulación de logs
- Eliminación de evidencias
- Accesos indebidos a auditorías

Simulación de ataque

Un atacante con acceso privilegiado podría alterar registros sin mecanismos visibles de integridad o monitoreo centralizado.

Riesgo

- Pérdida de trazabilidad
- Encubrimiento de incidentes
- Respuesta tardía

Impacto: Alto

Severidad: Alto

Mitigación

- SIEM
- Logs inmutables
- Alertas automáticas

Mejora recomendada

Implementar SIEM centralizado y monitoreo en tiempo real.

Hallazgo 8 — Gestión débil de roles y privilegios**Observación**

Existen roles de invitados y controles débiles visibles en la administración de accesos.

Superficie de ataque

- RBAC

- Gestión de usuarios
- Panel administrativo

Vulnerabilidad teórica

Posibles fallas de autorización y escalación de privilegios.

Pruebas hipotéticas

- Manipulación de roles
- Accesos indebidos
- Escalación horizontal y vertical

Simulación de ataque

Un atacante podría aprovechar validaciones débiles para acceder a funcionalidades restringidas.

Riesgo

- Escalación de privilegios
- Acceso indebido
- Compromiso administrativo

Impacto: Crítico

Severidad: Crítico

Mitigación

- RBAC robusto
- Restricciones estrictas de roles
- Validaciones backend

Mejora recomendada

Implementar control centralizado de privilegios y validación estricta de roles.

Hallazgo 9 — Validación débil de correos electrónicos

Observación

El sistema acepta correos Gmail genéricos y no utiliza dominios corporativos diferenciados.

Superficie de ataque

- Registro
- Gestión de identidad

Vulnerabilidad teórica

Facilidad para creación de identidades falsas y baja trazabilidad.

Pruebas hipotéticas

- Uso de correos temporales
- Creación masiva de identidades

Simulación de ataque

Un atacante podría generar múltiples identidades falsas para ocultar actividad maliciosa.

Riesgo

- Suplantación
- Abuso de cuentas
- Dificultad de trazabilidad

Impacto: Medio-Alto

Severidad: Media-Alta

Mitigación

- Validación avanzada de correo
- Restricción de dominios temporales

Mejora recomendada

Implementar reputación de dominios y controles anti disposable email.

Hallazgo 10 — Contraseñas protegidas parcialmente mediante hashing

Observación

Las contraseñas se encuentran hasheadas, aunque persisten debilidades generales en autenticación y control de acceso.

Superficie de ataque

- Base de datos
- Sistema de autenticación

Vulnerabilidad teórica

Protección parcial frente a ataques offline, pero insuficiente frente a debilidades del sistema de login.

Pruebas hipotéticas

- Validación de hashes
- Evaluación de algoritmos utilizados

Simulación de ataque

Aunque los hashes dificultan cracking offline, un atacante aún podría comprometer cuentas mediante ataques al login.

Riesgo

- Compromiso indirecto de cuentas
- Persistencia de debilidades de autenticación

Impacto: Medio

Severidad: Medio

Mitigación

- Mantener hashing seguro
- Fortalecer autenticación

Mejora recomendada

Migrar a Argon2id y complementar con MFA obligatorio.

